

****20.11.2024****

****Sanction for Violation of GDPR****

The National Authority for the Supervision of Personal Data Processing completed, in October 2024, an investigation into the operator Raiffeisen Bank S.A. and found a violation of the provisions of Article 32 paragraph (4) in conjunction with Article 32 paragraph (1) letters b) and d) and paragraph (2) of Regulation (EU) 2016/679 (GDPR).

As such, the operator was sanctioned with a fine of 99,466 lei, equivalent to 20,000 EURO.

The investigation was initiated following the fact that Raiffeisen Bank S.A. submitted three notifications to the National Authority for Supervision regarding breaches of personal data security, as follows:

The operator was notified by a client who reported the contracting of a loan in their name. During the investigation, it was found that an employee of the operator illegally used the client's loan application, as well as other documents related to this application, despite the client having informed Raiffeisen Bank S.A. that they were withdrawing this application. The employee of the operator performed cash withdrawal transactions from ATMs and bank transfer operations in the name of several data subjects, affecting the following categories of personal data: name, surname, personal identification number, home/residential and correspondence address, fixed/mobile phone number, date of birth, name and address of the employer, product IP, product/account status, grant date, grant term, amounts granted, amounts owed, due date, currency, payment frequency, amount paid, monthly rate, outstanding amounts, number of outstanding installments, number of days of delay, delay category, product closure date, number of inquiries, transaction history, direct debit contracts, deposits, savings accounts, investment funds.

As such, it was found that the operator Raiffeisen Bank S.A. did not take measures to ensure that any natural person acting under its authority and having access to personal data only processes them at the request of the operator, which led to unauthorized access and/or unauthorized disclosure of personal data transmitted, stored, or processed through the IT applications used by the operator in the lending activity by its employee.

Raiffeisen Bank S.A. notified that two of its employees provided confidential information about a client's transactions to a former employee of the bank through the use of Facebook, Messenger, and WhatsApp, who in turn forwarded it to relatives of the client.

During the investigation, it was found that Raiffeisen Bank S.A. did not take measures to ensure that any natural person acting under its authority and having access to personal data only processes them at the request of the operator, which led to unauthorized access and unauthorized disclosure of the client's data (name, surname, personal identification number, home/correspondence address, account number, transaction dates, transaction amounts, payment beneficiaries).

The operator was notified by a client who reported the existence of unsolicited products in their name, as well as missing amounts of money from their account. Internal checks revealed that an employee of Raiffeisen Bank S.A. performed numerous illegal operations in the name of several clients of the operator, such as: repeatedly modifying contact details (phone and email); using the Smart Mobile service; opening current accounts; opening savings accounts; establishing and liquidating deposits; requesting credit products, completing and signing the related documentation (loan/credit card); preparing and signing payment orders; redeeming fund units; requesting and using three debit cards. During the investigation, it was found that, from 2015 until March 2023, the personal data of several clients of Raiffeisen Bank S.A. were accessed and disclosed without authorization as a result of actions taken by an employee of the operator for the purpose of obtaining financial products in the name of the affected data subjects.

Consequently, in relation to the criteria for individualizing the sanction provided by Article 83 paragraph (2) of Regulation (EU) 2016/679, the operator Raiffeisen Bank S.A. was fined 99,466 lei, equivalent to 20,000 euros, for violating the provisions of Article 32 paragraph (4) in conjunction with Article 32 paragraph (1) letters b) and d) and paragraph (2) of the GDPR.

At the same time, under Article 58 paragraph (2) letter d) of Regulation (EU) 2016/679, the following corrective measures were ordered:

- the technical and organizational implementation of a procedural plan that includes a process for

periodic testing, evaluation, and assessment of all actions for entering/updating personal data for the data subjects (clients), including the notification and consent of the client in any form regarding any changes to the personal data that may be made by the employees of Raiffeisen Bank S.A.;

- in order to ensure regular information regarding the risks of unauthorized processing of personal data by employees, it is required to disseminate this information at intervals of no more than 6 months, including the necessity of proving acknowledgment by each of the employees who have access to personal data and responsibilities in the current activity of processing client data.

****Legal and Communication Department****

****N.A.S.P.D.C.P****